

01 — Secure Identity and Access (15–20%)

Official subsections:

- 1. Manage security controls for identity and access
 - 2. Manage Microsoft Entra application access and managed identities
-

1. Azure RBAC vs Microsoft Entra roles — the single most tested distinction

	Azure RBAC	Microsoft Entra roles
Controls access to	Azure resources — subscriptions, RGs, VMs, storage, Key Vault	Entra ID objects — users, groups, devices, app registrations, licences
Scope levels	Management group → Subscription → Resource group → Resource	Tenant-wide (or administrative unit , or app-scoped)
Where you manage it	Resource's Access control (IAM) blade	Entra ID → Roles and administrators
Definition format	JSON with <code>Actions</code> / <code>NotActions</code> / <code>DataActions</code> / <code>NotDataActions</code>	JSON with <code>rolePermissions</code> / <code>allowedResourceActions</code>

Example roles	Owner, Contributor, Reader, User Access Administrator, Virtual Machine Contributor	Global Administrator, User Administrator, Security Administrator, Application Administrator
Data plane support	Yes, via <code>DataActions</code> (e.g. Storage Blob Data Reader)	N/A

The bridge between them: a Global Administrator can **elevate access** (Entra ID → Properties → *Access management for Azure resources* → Yes). This grants them **User Access Administrator** at the **root scope** /, above all management groups. Remove it after use. This is a classic exam answer for *"an admin cannot see any subscriptions"*.

Trap: Global Administrator does **not** grant Azure resource access by default. Owner does **not** grant Entra directory access. They are separate systems.

Role assignment = 3 parts

Security principal (user, group, service principal, managed identity) + **role definition** + **scope**.

- Permissions **inherit downward** only. An assignment at RG scope cannot be limited to one VM inside it — assign at the VM instead.
- Effective permission is the **union** of all assignments. There is no "deny wins" between role assignments.
- **Deny assignments** *do* override allows, but you cannot create them directly — they come from Azure Blueprints (deprecated) and Azure managed applications.
- **Owner** vs **Contributor**: Contributor can do everything Owner can **except** manage access (create role assignments). **User Access Administrator** can *only* manage access.
- **Reader** vs **Security Reader**: Security Reader is an Entra role for security data; Reader is Azure RBAC for resources.

Built-in roles worth memorising

Role	Grants
Owner	Full access including assigning roles
Contributor	Full management, cannot assign roles or manage locks
Reader	View only
User Access Administrator	Manage user access to Azure resources only
Security Admin (Defender for Cloud)	Edit security policies, dismiss alerts and recommendations
Security Reader	View recommendations, alerts, policies, states
Storage Blob Data Contributor	Data plane — read/write/delete blobs
Key Vault Secrets User	Data plane — read secret contents
Key Vault Administrator	All data plane operations on keys, secrets, certificates
Virtual Machine Administrator Login / User Login	Sign in to VM with Windows admin or regular user rights

Custom Azure roles

```
{
  "Name": "Virtual Machine Operator",
  "IsCustom": true,
  "Description": "Start and restart VMs, no delete.",
  "Actions": [
    "Microsoft.Compute/virtualMachines/start/action",
    "Microsoft.Compute/virtualMachines/restart/action",
    "Microsoft.Compute/virtualMachines/read"
  ],
}
```

```
"NotActions": [],  
"DataActions": [],  
"NotDataActions": [],  
"AssignableScopes": ["/subscriptions/<sub-id>"]  
}
```

Rules that get tested:

- `AssignableScopes` defines **where the role can be assigned**, not what it can touch. It cannot be / (root) for custom roles. Must be at least one management group or subscription.
- **Wildcards are not allowed in `NotActions`.**
- `NotActions` **subtracts** from `Actions`; it is not a deny — a different assignment can still grant it.
- **Limit: 5,000 custom roles per tenant** (2,000 in Azure China and Azure US Government).
- Custom roles can be created in the portal, PowerShell (`New-AzRoleDefinition`), CLI (`az role definition create`), or REST.

Custom Entra roles

Require **Microsoft Entra ID P1**. Built on **permission sets** and can be scoped to a single **app registration** or an **administrative unit** — that is the answer when a scenario needs "manage only this one app's credentials".

2. Privileged Identity Management (PIM)

Requires Microsoft Entra ID P2 (or Entra ID Governance). Applies to **Entra roles**, **Azure resource roles**, **PIM for Groups**, and PIM for Microsoft Entra ID Governance.

Concept	Meaning
---------	---------

Eligible assignment	User must activate to use the role. This is the just-in-time model.
Active assignment	Permanently usable (can still be time-bound with start/end dates).
Activation	User requests → optionally MFA, justification, ticket number, approval → role granted for a max duration
Approval	Named approvers must approve activation; if none specified, defaults to Privileged Role Administrator
Access review	Periodic recertification of who holds the role
Alerts	e.g. "Roles are being assigned outside of PIM", "Too many Global Administrators"
Discovery and insights	Finds standing privileged assignments to convert to eligible

Settings per role (Role settings → Edit): activation maximum duration (default 8 hours, max 24), require MFA on activation, require Conditional Access authentication context, require justification, require ticket info, require approval, notification recipients.

Two-step model to remember: you *assign eligibility* once; the user *activates* repeatedly. An eligible user showing "no permissions" simply has not activated.

Exam pattern: "Administrators should have permanent read but require approval for write, for a maximum of 4 hours." → Active assignment for Reader + **Eligible** assignment for Contributor with approval required and max duration 4 hours.

3. MFA and mandatory MFA enforcement

Ways to require MFA (mutually exclusive in practice)

Method	Licence	Notes
Security defaults	Free	All-or-nothing: MFA for all users, blocks legacy auth, protects privileged actions. Cannot coexist with Conditional Access — you must disable it to use CA.
Conditional Access	Entra ID P1	Granular. The recommended method.
Per-user MFA (legacy)	Free	Enabled/Enforced/Disabled per user. Legacy; avoid.

Microsoft's mandatory MFA rollout (current, and fair game)

- **Phase 1** (from Oct 2024): MFA required to sign in to the **Azure portal**, Microsoft Entra admin center, and Microsoft Intune admin center.
- **Phase 2** (from **1 October 2025**): extends to **Azure CLI, Azure PowerShell, Azure mobile app, IaC tools, and control-plane REST APIs** for **create, update, and delete** operations. **Read-only operations remain exempt.**
- Tenants could **postpone Phase 2 until 1 July 2026** — that deferral window has now closed.
- Applies to **all** user accounts including break-glass accounts. Workload identities (service principals, managed identities) are **not** in scope — this is why automation should use managed identities.

Authentication strengths

Conditional Access can require a specific **authentication strength** rather than just "MFA": *Multifactor authentication, Passwordless MFA, or Phishing-resistant MFA* (FIDO2 security key, Windows Hello for Business, certificate-based auth). "Phishing-resistant" in a stem means **FIDO2/WHfB/CBA**, not the Authenticator app.

4. Conditional Access

If then . Requires **Entra ID P1**.

Assignments (the "if")

- **Users / groups / workload identities** — include/exclude. Always **exclude break-glass accounts**.
- **Target resources** — cloud apps (e.g. *Windows Azure Service Management API* covers portal/CLI/PowerShell/ARM), user actions (register security info, register or join device), global secure access, **authentication context**.
- **Network** — named locations (IP ranges, countries), trusted locations.
- **Conditions** — sign-in risk, user risk, **insider risk**, device platform, client apps (browser, mobile/desktop, **legacy auth: Exchange ActiveSync and other clients**), device filter, authentication flows.

Access controls (the "then")

- **Block access** — wins over any grant.
- **Grant with:** require MFA, require **authentication strength**, require device marked **compliant** (Intune), require **Hybrid Entra joined** device, require **approved client app**, require **app protection policy**, require password change, require **terms of use**. Multiple controls → *Require all* or *Require one*.
- **Session** — sign-in frequency, persistent browser session, **Conditional Access App Control** (Defender for Cloud Apps — real-time session monitoring/blocking of downloads), app-enforced restrictions, **Continuous Access Evaluation (CAE)**, disable resilience defaults, token protection.

Operating it

- **Report-only mode** — evaluates policy and logs the result without enforcing. Always deploy here first.

- **What If tool** — simulate a specific user/app/condition and see which policies apply.
- Policies are evaluated **for every sign-in**; all matching policies must be satisfied; **any block wins**.
- Sign-in logs → **Conditional Access** tab shows which policies applied and why.

Trap: Conditional Access does not apply to **Entra role activation** unless you wire it via **authentication context** in PIM role settings.

Identity Protection (Entra ID P2)

- **Sign-in risk** = probability that the *request* isn't from the legitimate owner (anonymous IP, atypical travel, unfamiliar sign-in properties, malware-linked IP, Entra threat intelligence).
- **User risk** = probability the *account* is compromised (**leaked credentials**, Entra threat intelligence).
- Remediation: **sign-in risk** → **require MFA**; **user risk** → **require secure password change**. Memorise that pairing.
- Risk-based policies are best implemented **inside Conditional Access** (the legacy standalone Identity Protection policies are being retired in favour of CA).

5. Managed identities

	System-assigned	User-assigned
Lifecycle	Tied to the resource — created and deleted with it	Standalone Azure resource, independent lifecycle
Relationship	1:1 — one identity, one resource	1:many — one identity shared by many resources
Use when	Single workload, identity should die with the resource	Pre-provisioning access, or a fleet of VMs needing the same permissions

Sharing	Cannot be shared	Can be shared
---------	------------------	---------------

- **Zero credential management** — no secrets in code or config. This is the answer to "without storing credentials".
- Token acquisition on a VM is via the **Azure Instance Metadata Service (IMDS)** at `http://169.254.169.254/metadata/identity/oauth2/token` (requires the `Metadata: true` header).
- Under the hood a managed identity **is** a service principal in Entra ID, but you cannot manage its credentials.
- Not all Azure services support managed identity — check the support list.
- Grant it access using normal **Azure RBAC** (or a Key Vault access policy).

Exam pattern: "An app on a VM must read a secret from Key Vault without storing credentials, and the identity must be removed when the VM is deleted." → **System-assigned managed identity + Key Vault Secrets User** role.

"Twenty VMs must all access the same storage account with one identity." → **User-assigned managed identity**.

6. App registrations, service principals, and enterprise applications

This trio confuses people. Get it straight:

Object	What it is	Where you see it
--------	------------	------------------

Application object (app registration)	The global definition / template of the app. Lives only in the home tenant . Holds redirect URIs, certificates and secrets, API permissions, app roles, token config.	Entra ID → App registrations
Service principal	The local instance of the app in a given tenant. What is actually granted permissions and used to sign in. One per tenant the app is used in.	Entra ID → Enterprise applications
Enterprise application	The portal blade for viewing/managing service principals , including SSO config, user assignment, provisioning, and permission grants.	Entra ID → Enterprise applications

- Registering an app creates the **application object plus a service principal in your home tenant**.
- A **multi-tenant** app has one application object in the publisher's tenant and a service principal in **every** consuming tenant.
- Three service principal types: **Application** (the common one), **Managed identity**, **Legacy**.

Credentials

- **Client secret** — string, max lifetime **24 months** (portal offers 3/6/12/18/24 months or custom). Least secure.
- **Certificate** — recommended over secrets.
- **Federated credentials / workload identity federation** — no secret at all; trust an external IdP (GitHub Actions, Kubernetes). This is the modern answer for CI/CD.

7. API permissions, scopes, and consent

Delegated vs application permissions

	Delegated (scopes)	Application (app roles)
Acts as	The signed-in user — app is limited to the intersection of its permission and the user's own rights	The app itself , no user present
Used by	Interactive apps	Daemons, background services
Consent	User or admin	Admin consent always required
Token claim	scp	roles

Trap: an app with delegated `Files.Read` cannot read files the signed-in user cannot read. An app with application-permission `Files.Read.All` can read **everything** — that is why it always needs admin consent.

Consent controls

- **User consent settings** (Entra ID → Enterprise applications → Consent and permissions): *Do not allow user consent / Allow user consent for apps from verified publishers, for selected permissions / Allow user consent for all apps*. The middle option is the recommended hardening answer.
- **Admin consent workflow** — users request, designated reviewers approve. The answer for "users should be able to request access to apps they cannot consent to".
- **Grant admin consent for** button — consents on behalf of all users in the tenant.
- **App consent policies** define which permissions users may consent to (`Microsoft.Graph` PowerShell for custom policies).
- **Illicit consent grant attack** — the reason to restrict user consent;

investigate via the *OAuth apps* view and audit logs.

- **User assignment required?** = Yes → only assigned users/groups can access the enterprise app.
-

8. Access reviews and entitlement management (Entra ID P2)

- **Access reviews** cover: security and Microsoft 365 group members, assigned users of enterprise apps, **Entra role** assignments, **Azure resource role** assignments, access package assignments, and **guest users**.
 - Reviewers: selected users/groups, **members review their own access**, **managers of users**, or group owners.
 - Settings: recurrence, duration, **auto-apply results**, "If reviewers don't respond" → No change / **Remove access** / Approve access / Take recommendations.
 - **Entitlement management / access packages** — bundle resources (groups, apps, SharePoint sites) with a policy defining who can request, approval flow, and expiry. The answer for "external partners should request bundled access that expires".
-

9. Other identity topics that appear

- **Administrative units (AU)** — scope Entra role assignments to a subset of users/groups/devices (e.g. a helpdesk admin for one region only). Restricted management AUs prevent even tenant admins from modifying members.
- **Entra Password Protection** — global banned password list (always on) plus a **custom banned list** (up to 1,000 terms). Extend to on-premises AD with the **DC agent + proxy**, in Audit or Enforced mode.
- **SSPR** — self-service password reset; with **password writeback** for hybrid.

- **B2B collaboration** — guests get a #EXT# UPN. Governed by **External collaboration settings** and **Cross-tenant access settings** (inbound/outbound, trust MFA claims from home tenant, B2B direct connect).
 - **Resource locks** — `CanNotDelete` and `ReadOnly`. Apply at subscription/RG/resource; inherited downward; the **most restrictive** lock wins. Only **Owner** and **User Access Administrator** can create/delete locks. Locks apply to the **control plane**, not the data plane (a `ReadOnly` lock on a storage account does not stop blob writes).
-

Rapid-fire self-test

1. Which role can assign roles but do nothing else? → **User Access Administrator**
2. Wildcards allowed in `NotActions`? → **No**
3. Custom RBAC role limit per tenant? → **5,000**
4. Sign-in risk remediation vs user risk remediation? → **MFA vs secure password change**
5. Security defaults and Conditional Access together? → **No, mutually exclusive**
6. Which managed identity type can be shared across VMs? → **User-assigned**
7. Which permission type always needs admin consent? → **Application permissions**
8. Where does the application object live for a multi-tenant app? → **Only the home tenant**
9. Licence for PIM? → **Entra ID P2**
10. Licence for Conditional Access? → **Entra ID P1**